COMPTIA SECURITY+ SY0-701 | DOMAIN 2 · THREATS, VULNERABILITIES, AND MITIGATIONS (22%)

Security+ 2.3 · Malicious Updates

Mestre CyberSec · **Lesson 2.3 — Malicious Updates** (5:45) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Update envenenado: atacante compromete o CANAL DE UPDATE (SolarWinds 2020 — 18.000 clientes baixaram update com backdoor). Defesa: code signing (assinatura do update), verify origem, supply chain security.

💡 Key Exam Highlights & Critical Concepts

- SolarWinds: o caso clássico — 18k empresas via 1 update envenenado
- Defesa: code signing + verificação de origem do update

🎯 Exam Tips & Typical CompTIA Scenarios

- 'software update distributes malware' = supply chain attack / poisoned update

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 2.3 — Malicious Updates)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Poisoned Update

A legitimate software update mechanism used to deliver malware or unauthorized code to trusted users; the update appears to come from a trusted vendor or channel but has been altered or backdoored.

⚠️ ***Exam Trap:*** *Se a questão disser 'software update distributes malware', pense em poisoned update / supply chain attack, não em phishing.*

• Supply Chain Attack

An attack that compromises a trusted third party, vendor, supplier, or update mechanism to deliver malicious code to downstream customers.

⚠️ ***Exam Trap:*** *SolarWinds é o exemplo clássico da prova; 'trusted vendor compromise' = supply chain attack.*

• Code Signing

Use of a digital signature to verify that software or update code is authentic and has not been modified since it was signed by the publisher.

⚠️ ***Exam Trap:*** *Defesa contra atualizações envenenadas; verifique o certificado do publicador e a integridade antes da instalação.*

• Digital Signature

Cryptographic mechanism that provides integrity, authentication, and non-repudiation; code signing uses it to validate update origin and integrity.

⚠️ ***Exam Trap:*** *Se code signing for mencionado, ele depende de digital signatures e validação de certificado.*

• Update Channel

The trusted path or distribution server through which vendors deliver patches and updates; compromising it lets attackers push malicious updates to many systems.

⚠️ ***Exam Trap:*** *Poisoned update attacks target the update/distribution channel, not just an individual endpoint.*

• SolarWinds Orion Attack (SUNBURST)

A 2020 supply chain attack where the SolarWinds Orion update channel was compromised, delivering a backdoored update (SUNBURST) to about 18,000 customers.

⚠️ ***Exam Trap:*** *SolarWinds = poisoned update / supply chain; SUNBURST é o malware backdoor associado.*

• Backdoor

A hidden malicious access method inserted into software or an update, allowing attackers to bypass normal authentication and control systems.

⚠️ ***Exam Trap:*** *Poisoned updates often install backdoors; backdoor não é ransomware, embora possa levar a ele.*

• Software Bill of Materials (SBOM)

An inventory of software components and dependencies; it helps identify and verify supply-chain components affected by malicious updates or vulnerabilities.

⚠️ ***Exam Trap:*** *SBOM é ferramenta de gestão de risco da cadeia de suprimentos; saiba que lista componentes e dependências.*

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

After news of a supply chain attack against a widely used network monitoring platform, the CISO asks the security team to determine as quickly as possible whether the organization runs any affected version of that software. Which action best meets this requirement?

A) Review the software bill of materials (SBOM) and the internal asset inventory for the affected product and versions.

B) Enable verbose logging on all endpoint antivirus agents.

C) Perform a full disk encryption audit across all servers.

D) Require multi-factor authentication on the vendor's support portal.

QUESTION 2 · EXAM SCENARIO

A systems administrator downloads a firmware update from a vendor's portal and must confirm the file is authentic and was not modified before deploying it to production servers. Which action best accomplishes this?

A) Compare the file's size and name against the listing on the vendor's download page.

B) Scan the file with the endpoint antivirus and confirm it produces no detections.

C) Verify the digital signature on the package using the vendor's published public key and confirm the signing certificate chains to a trusted root.

D) Compute the file hash and compare it with the hash displayed on the same vendor download page.

QUESTION 3 · EXAM SCENARIO

A financial firm enforces a control that rejects any software update lacking a valid digital signature from the vendor. Nevertheless, a malicious update was installed and its signature validated correctly, because the attacker had compromised the vendor's build pipeline and signed the payload with the vendor's legitimate certificate. Which improvement most directly addresses this gap?

A) Increase the frequency of signature validation checks on the distribution server.

B) Monitor post-install process behavior and outbound network activity on hosts running the updated software.

C) Require multi-factor authentication for administrators who apply updates.

D) Move the update distribution server to an isolated VLAN.

QUESTION 4 · EXAM SCENARIO

A development team's CI/CD pipeline downloads dependencies directly from a public package repository during every build, without verifying integrity. An attacker publishes a package whose name is nearly identical to an internal library the pipeline requests, and that malicious package is installed into the build. Which control best mitigates this risk?

A) Enable TLS inspection on the build server's outbound traffic.

B) Run all builds inside isolated containers.

C) Require two-person code review before merges.

D) Resolve dependencies only from an internal, curated artifact repository that proxies approved packages.

QUESTION 5 · EXAM SCENARIO

An attacker manipulates DNS so that a software vendor's update domain resolves to infrastructure under the attacker's control, and clients in the organization download a rogue update from it. Which control most directly prevents the update client from trusting a certificate presented by an unintended server?

A) Implement certificate and public-key pinning in the update client.

B) Enable DNS over HTTPS (DoH) on all endpoints.

C) Increase the DNS record TTL for the vendor's domain.

D) Disable the automatic update feature on all clients.

QUESTION 6 · EXAM SCENARIO

An enterprise must distribute a critical update to 20,000 endpoints but wants to limit the impact if the update turns out to be compromised or defective. Which deployment practice best limits the blast radius?

A) Schedule the update deployment during off-peak hours.

B) Require end-user approval before each installation.

C) Deploy first to a small pilot ring of representative systems and monitor before broad rollout.

D) Distribute the update using multicast to reduce bandwidth consumption.

QUESTION 7 · EXAM SCENARIO

Investigators suspect that a trusted server-management platform used in the environment was backdoored through a poisoned vendor update. Which finding would be the strongest indicator of active command-and-control from that platform?

A) An increase in CPU utilization during the nightly backup window.

B) Periodic outbound connections from the management server to unknown external IP addresses at regular intervals.

C) Local firewall log entries showing blocked inbound port scans.

D) New entries added to the server's local hosts file by an administrator.

QUESTION 8 · EXAM SCENARIO

During vendor due diligence, the security team wants documentation that identifies the third-party and open-source components contained in an application, so the organization can quickly assess exposure if one of those components is later found vulnerable. Which artifact best meets this need?

A) A software bill of materials (SBOM) for the product.

B) The vendor's SOC 2 Type II report.

C) A summary of the vendor's most recent penetration test.

D) The vendor's business continuity and disaster recovery plan.

QUESTION 9 · EXAM SCENARIO

After an incident in which a user installed a rogue application that masqueraded as a vendor update, the security team wants to ensure that only software from approved, cryptographically verified publishers can execute on workstations. Which control best achieves this?

A) Disable USB mass storage devices on all workstations.

B) Enable the host-based firewall in default-deny mode.

C) Require longer, more complex user passwords.

D) Enforce application allowlisting that only permits executables signed by trusted publishers.

QUESTION 10 · EXAM SCENARIO

A software vendor notifies the organization that its update server was breached and that a malicious update was distributed to customers. The affected servers in the organization run a management agent with high privileges. Which action should the incident response team take first?

A) Wait for the vendor to publish a remediated update before taking any action.

B) Send an organization-wide email describing the attack and its indicators.

C) Isolate the affected management servers and begin rotating credentials and tokens that may have been exposed.

D) Immediately remove the vendor's product from the approved software list.

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option A — Review the software bill of materials (SBOM) and the internal asset inventory for the affected product and versions.

An SBOM enumerates the components and versions that make up a product, so combined with an accurate asset inventory it is the fastest way to determine exposure to a compromised software version. Verbose AV logging, disk encryption audits, and MFA on a vendor portal do not reveal which versions of the affected product are installed in the environment.

Question 2: Option C — Verify the digital signature on the package using the vendor's published public key and confirm the signing certificate chains to a trusted root.

A digital signature verified with the vendor's public key proves both integrity and origin, and cannot be forged without the vendor's private key. Hash values or filenames taken from the same web page could be altered if that site were compromised, and antivirus scanning is unreliable against a signed backdoor.

Question 3: Option B — Monitor post-install process behavior and outbound network activity on hosts running the updated software.

When the attacker controls the vendor's signing process, signature validation alone cannot separate good builds from bad ones, so defense in depth is required. Behavioral monitoring of what the updated application does after installation, such as unexpected child processes, file or registry changes, and unusual outbound connections, can expose the backdoor. Re-validating signatures, MFA for administrators, and VLAN segmentation do not detect a validly signed malicious binary.

Question 4: Option D — Resolve dependencies only from an internal, curated artifact repository that proxies approved packages.

Typosquatting and dependency confusion abuse an uncurated public repository. Forcing resolution through an internal artifact repository containing only vetted, pinned packages removes the attacker's ability to inject a similarly named package into the build. TLS inspection, containers, and code review do not prevent the wrong or malicious dependency from being pulled.

Question 5: Option A — Implement certificate and public-key pinning in the update client.

Public-key or certificate pinning makes the update client accept only the vendor's expected certificate or public key, so a rogue server cannot be trusted even if it presents a fraudulently issued certificate. DoH only protects the DNS query itself, a longer TTL can extend exposure, and disabling updates leaves clients running known-vulnerable software.

Question 6: Option C — Deploy first to a small pilot ring of representative systems and monitor before broad rollout.

A staged rollout with a monitored pilot ring confines the effects of a poisoned or defective update to a small group before it reaches the full estate. Deployment timing, user approval prompts, and multicast distribution affect performance or user experience, not the blast radius of a malicious update.

Question 7: Option B — Periodic outbound connections from the management server to unknown external IP addresses at regular intervals.

Backdoors delivered by poisoned updates typically beacon to attacker-controlled infrastructure. Regular, unexplained outbound connections from a management server to unknown external addresses are a classic C2 indicator. Backup-related CPU load is normal activity, blocked inbound scans represent reconnaissance against the organization rather than outbound C2, and documented administrative hosts file edits are not malicious indicators on their own.

Question 8: Option A — A software bill of materials (SBOM) for the product.

An SBOM enumerates the components and versions embedded in a product, which is exactly what is needed to triage exposure when one of those components is later compromised. A SOC 2 report covers control practices, a penetration test summary describes past findings, and BCDR plans address availability; none of them identify embedded components.

Question 9: Option D — Enforce application allowlisting that only permits executables signed by trusted publishers.

Allowlisting based on publisher code-signing certificates ensures that only binaries signed by trusted publishers can execute, directly blocking rogue or self-signed packages posing as updates. USB blocking, default-deny firewalls, and password complexity address other attack vectors and do not stop execution of a locally installed unsigned executable.

Question 10: Option C — Isolate the affected management servers and begin rotating credentials and tokens that may have been exposed.

With a high-privilege backdoored agent, the priority is to stop the threat from being leveraged: isolate the affected hosts to cut command-and-control and lateral movement, then rotate the credentials and tokens those agents could have harvested. Waiting leaves the attacker in place, mass emailing does not contain the threat, and administratively delisting the product does not remove the malware.